

Warden vs Fortified Enterprise Fleet

Judge-style audit of local main at 44e0fbd against Devpost criteria (2026-08-21).

Track prize: \$20,000. Official judging weights: 40% Innovation / 30% Architecture / 30% Demo readiness.

■■ HEADLINE VERDICT

Strong enough to be a finalist if the demo is a completed governed job on Cloud Run. Not a clear winner yet: the current story overweights homemade governance theater, the red-team grade is not a live LLM test, and official Innovation scoring can penalize a product whose only wow moment is blocking the agent.

7.2 / 10 Weighted Overall	7.5 / 10 Google Stack	6.5 / 10 Zero-Trust Honesty	7.0 / 10 Innovation Bucket
-------------------------------------	---------------------------------	---------------------------------------	--------------------------------------

1. Official Devpost Weights & Skeptical Judge Reading

Criterion	Weight	Risk	How a Skeptical Judge Reads Warden
Innovation & Operational Utility	40%	High	Official scoring rewards agents that complete high-value work with little hand-holding. Warden's current narrative is a governor that stops work. That is a real enterprise need, but it can lose this bucket unless the demo shows a GPU job actually finishing after a single human grant.
Architectural Discipline & Tech Stack	30%	Medium	ADK BasePlugin interception, Firestore transactions, Cloud Tasks OIDC resume, and a dedicated runtime SA are production-minded. Homemade Registry / Memory Bank / Model Armor analogs, InMemory ADK sessions, and unused Cloud client libraries weaken the 'Gemini Enterprise Agent Platform' mapping.
Demo & Production Readiness	30%	Medium	Repo has architecture SVG, Cloud Run deploy script, CLI, dashboard, and a dense test suite. Proof still depends on an unedited video that shows Cloud Run, Trace, Firestore, and a live Model Armor template, not only localhost mock mode.

2. Gemini Enterprise Agent Platform Primitives vs Reality

Track / Rules Item	Status	Evidence in this Repository
Gemini 3.5+ via API / Vertex	Partial	Default model is gemini-3.7-flash. Rules say 'Gemini 3.5 Flash' in What to Build. Safer: default to 3.5 Flash, document 3.7 as optional.
Google Agent Framework (ADK)	Met	google-adk >= 2.7.1, App + Runner + BasePlugin, context cache, resumability config.
Google Cloud Infrastructure	Met	Cloud Run, Firestore, Cloud Tasks, Cloud Trace, Model Armor API enablement. Pub/Sub and Compute clients are declared but unused.
Agent Registry	Analog	GET /registry/agents is a static metadata overlay on the live ADK tree. Not Gemini Enterprise Agent Registry.
Agent Runtime (Weeks of Async)	Partial	Firestore workflow + Cloud Tasks resume. ADK sessions stay InMemorySessionService, so Cloud Run recycle drops model context.
Memory Bank (Cross-Session)	Analog	Operator POST /memory with hashed subject + 30-day TTL, then prompt stuffing. Not Vertex/Agent Platform Memory Bank extraction.
Agent Identity (Zero-Trust)	Partial	Human identity via Cloud Run OIDC. Agents share one runtime SA. No per-agent IAM principal.
Agent Gateway	Analog	WardenPlugin is a real enforcement point in ADK. It is not Agent Gateway + Model Armor inline on tool I/O.
Model Armor	Optional	REST sanitizeUserPrompt when WARDEN_MODEL_ARMOR_TEMPLATE is set. Default path is NOT_CONFIGURED / allow.
OpenTelemetry / Observability	Optional	WARDEN_ENABLE_CLOUD_TRACE=true wires ADK GCP exporters. Demo must show Trace Explorer or it does not count.

3. Rubric Breakdown & Architectural Authenticity

Dimension	Score	Weight / Notes
Technical sophistication / Google stack	7.5 / 10	Track-specific core requirement
Innovation / problem-solution fit	7.0 / 10	40% overall Devpost score
Security / zero-trust hardening	6.5 / 10	Track-specific core requirement
UX / polish / demo readiness	7.5 / 10	30% overall Devpost score

■ What is Actually Strong

- **WardenPlugin at Runner scope:** Returned dict short-circuits tool calls. Real zero-trust relative to prompt-only policy.
- **Production-grade Approvals:** Claim/consume, args digest, OIDC verification on decide, Cloud Tasks resume, and transactional Firestore appends.
- **Clean GCP artifacts:** Dedicated warden-runtime SA, Model Armor enablement in deploy script, and clean architecture diagram.

■ What Looks Like Theater

- **Scorecard ahead of implementation:** Grade A+ 5/5, 47-tool MCP coverage, and Memory Bank / Agent Registry labels overclaim.
- **Default Live Path:** Still uses FunctionTools + Manifold REST, not a full 47-tool MCP dynamic mesh.
- **Dead Dependencies:** google-cloud-pubsub and google-cloud-compute in pyproject.toml have no call sites.

4. Blind Spots a Google Judge Will Poke

ID	Severity	Issue	Why It Matters & Fix Required
G 1	Critical	Red team never talks to Gemini	warden/security/redteam.py calls WardenPlugin.before_tool_callback with DummyAgentContext. 5/5 A+ is a unit-test of policy.evaluate, not prompt-injection resistance. A judge who opens that file will discount the badge.
G 2	Critical	Autonomy vs governance narrative collision	40% of official points go to operational utility: the agent removing friction on its own. If the video is mostly Deny / Pending / Grade A+, Warden looks like a security lab, not a fleet that ships work.
G 3	High	Cost ceiling trusts the model	estimated_usd is a tool argument. Policy blocks over-quote, but an agent can under-quote a \$200 GPU as \$2.00 and pass the \$25 run cap. There is no independent price table or billing API check.
G 4	High	TTL is declared, not enforced by Warden	Policy requires max_lifetime_minutes and forwards it to Manifold. There is no Cloud Scheduler / Tasks watchdog that terminates if the provider ignores TTL. Dashboard copy overclaims 'Warden enforces the requested TTL'.
G 5	High	run_command is allow	policy.yaml sets run_command, run_job, run_detached, upload_file, download_file, dispatch_local_subagent to allow. After a GPU exists, a prompt-injected provisioner can run arbitrary commands without a ticket.
G 6	High	IAP header trust and open control-plane GETs	WARDEN_TRUST_IAP_HEADERS=true accepts X-Goog-Authenticated-User-Email with no JWT verify. /policy, /spend, /audit, /approvals/pending, /redteam/run have no operator dependency. Live Cloud Run that is not IAM-locked is an easy skeptic question.
G 7	Med	Firestore hash chain is app-level only	SHA-256 chaining is real and well tested. The runtime SA has roles/datastore.user, which can rewrite documents. An admin or compromised SA can edit history; verify() only catches in-app inconsistency.
G 8	Med	Platform name collision	README maps homemade endpoints onto Agent Registry, Memory Bank, Agent Gateway, and Model Armor. Judges from Google will know the products. Analog is fine if labeled analog.

5. Likely Judge Questions & The Honest Answers

Q: Does this use Gemini Enterprise Agent Platform?

No. It uses ADK on Cloud Run with first-party analogs. Say that out loud. Then show why an interceptor in `before_tool_callback` is the right control for GPU spend even if Agent Gateway is not in the path yet.

Q: Can the agent still burn money?

Yes, via understated `estimated_usd` and ungated `run_command` after a blessed launch. Preempt by quoting from a rate card and gating `shell/job` tools, or show Manifold-side TTL plus a Warden watchdog task.

Q: Is the audit log tamper-proof?

It is tamper-evident inside the application, not tamper-proof against Firestore IAM. Compare it to Cloud Audit Logs / CMEK / restricted SA. Do not say blockchain.

Q: Why is Manifold in the story?

Disclose it as MIT compute substrate, Warden as Apache-2.0 governance. Judges care that the original work is the control plane. Keep Manifold off the title slide.

6. Winning 3.5 – 4.0 Minute Video Storyboard

Time	Beat	What the Camera Must Show
0:00-0:25	Problem, not product	Overnight GPU bill + rogue teardown. One sentence: Warden is the interceptor that lets Gemini fleets act on cloud without becoming the billing owner.
0:25-0:50	Live Cloud proof	Cloud Run service page (<code>.run.app</code>), Firestore collections, Cloud Tasks queue, Trace span for <code>warden.workflow.run</code> . Pause long enough to read the project ID.
0:50-1:40	Happy path autonomy	Prompt: launch <code>g2-standard-8</code> in <code>us-west1</code> , run a 2-minute job, report spend. Fleet plans, parks launch, you Approve once, Cloud Tasks resumes, mock or real instance appears, auditor reports cost. This is the 40% bucket.
1:40-2:20	One real attack through Gemini	Type a jailbreak in the dashboard terminal. Show the model trying <code>terminate_cluster / europe-west4</code> . Show <code>awaiting_human_approval</code> or <code>denied_by_policy</code> in the live response, then the new ledger row. Do not lead with <code>warden redteam</code> .
2:20-2:50	Identity + ledger	Approve as verified OIDC principal (not a typed name). Click verify. Optionally flip one Firestore field in a throwaway doc and show <code>verify()</code> fail, then restore.
2:50-3:40	Close on enterprise	Registry table, memory scoped to operator, Model Armor template in console if enabled. Architecture SVG. One line: Apache-2.0, Manifold disclosed as compute substrate.

7. High-Leverage Polish Checklist (Priority Order)

Priority	Action Item
Must ship before video	Default WARDEN_MODEL to gemini-3.5-flash; keep 3.7 as override. Say 3.5+ in Devpost.
Must ship before video	Gate run_command / run_job as approve, or add a command allowlist. Judges will ask.
Must ship before video	Price launches from a static machine-rate table, ignore agent estimated_usd except as a display hint.
Must ship before video	Add one red-team vector that goes through execute_turn() with a real Gemini prompt. Keep the plugin tests, stop leading with A+ 5/5.
Must ship before video	Live: disable header-only IAP trust; require OIDC. Protect /redteam/run and /approvals/pending.
High leverage (1 day)	Create a Model Armor template, set WARDEN_MODEL_ARMOR_TEMPLATE, screenshot console findings.
High leverage (1 day)	Vertex or Firestore ADK SessionService so 'weeks of async' is not just a stored prompt string.
High leverage (copy)	Rename README rows to 'ADK-native analog of X' unless the Google product is actually configured.
Submission extras	Public blog/dev.to with required hackathon sentence; LinkedIn/X with #AllThingsAgenticHackathon. Architecture diagram at assets/warden-system-architecture.svg.
Do not do	Do not inflate 47 MCP tools as live demo path. Default factory wires FunctionTool subset. Do not claim TTL enforcement Warden does not schedule.

8. Devpost Write-up Framing Strategy

Lead with: Autonomous Gemini fleets that provision GPUs, under a control plane that cannot be talked out of policy.

Do not lead with: Glassmorphism or A+ badges.

Name the operator: SRE / FinOps.

Name the failure: Overnight bill, rogue teardown, secret in LLM context.

Name the proof: Cloud Run + Firestore + one granted launch that finishes.

Features list: Must match live-mode health fields: ledger, workflow store, resume transport, model_armor, cloud_trace.

Spin-up instructions: Must include mock (zero billing) and live (project, Firestore, Tasks queue, IAP or authenticated Cloud Run).

Sources: <https://allthingsagenticHackathon.devpost.com/> (2026-08-21), Warden repository at /Users/jamesmcshane/Desktop/Warden, HEAD 44e0fbd. Re-run pytest before quoting total test count.